

Ваш офис — крепость? Как физический пентест вскрывает уязвимости, о которых вы не подозревали

 redsec.by/article/vash-ofis-krepost-kak-fizicheskij-pentest-vskryvaet-uyazvimosti-o-kotoryh-vy-ne-podozrevali

Red Teams | 22 октября 2025



В мире, где компании тратят миллионы на файрволы, антивирусы и шифрование, самая большая угроза может просто войти через парадную дверь.

Представьте: понедельник, утро. Директор вашей компании заходит в свой кабинет и находит на столе чужую визитку с лаконичной надписью "Мы были здесь". Ни взломанных замков, ни сработавшей сигнализации. Это не сценарий из голливудского фильма, а реальный результат физического тестирования на проникновение (пентеста) — аудита безопасности, который проверяет не цифровые, а вполне реальные стены, двери и бдительность сотрудников.

Физический пентест — это критически важный компонент комплексной оценки безопасности организации, который часто остается в тени традиционного кибертестирования. В современных условиях злоумышленники все чаще понимают, что обойти сложную цифровую защиту проще, получив физический доступ к серверу или рабочему месту ключевого сотрудника. Анонимный кейс, упомянутый выше, наглядно демонстрирует, как команда специалистов смогла обойти многоуровневую

систему безопасности и оставить "привет" на столе директора, используя лишь комбинацию технических навыков и социальной инженерии. Эта статья, подготовленная при участии специалистов по кибербезопасности, подробно раскрывает механику таких проверок, их методы и связь с нормативными требованиями, в том числе Техническими нормативными правовыми актами (ТНПА) Республики Беларусь.

Анатомия физического "взлома": этапы и методология

Успешная проверка физической безопасности — это тщательно спланированная операция, состоящая из нескольких ключевых этапов.

Фаза 1: Разведка и планирование — битва, выигранная до начала

Успешный физический пентест начинается задолго до непосредственного проникновения. На этом этапе собирается максимум информации из открытых источников для построения полной картины объекта.

Сбор информации из открытых источников (OSINT):

- **Изучение публичных данных:** Анализируются корпоративные сайты, страницы в социальных сетях, публикации в СМИ, вакансии и даже объявления о тендерах. Например, вакансия "Специалист по обслуживанию СКУД" может раскрыть название используемой системы доступа.
- **Анализ социальных сетей:** Профили сотрудников могут содержать фотографии офиса, пропусков, информацию о графиках работы или даже недовольство службой безопасности, что является ценной зацепкой.
- **Геолокационный анализ:** Спутниковые снимки и картографические сервисы (Google Maps, Яндекс.Карты) позволяют изучить периметр здания, определить расположение входов, парковок, курилок и даже окон кабинетов руководства.

Физическое наблюдение:

- **Визуальная оценка:** Команда пентестеров под видом обычных прохожих или клиентов соседних заведений наблюдает за объектом, фиксируя расположение камер, их "слепые зоны", типы замков и СКУД (Система контроля и управления доступом).
- **Анализ трафика:** Определяются часы пик, когда поток людей максимален и бдительность охраны снижена (обычно утро с 7:30 до 9:00), время пересменок охраны и обеденные перерывы.
- **Идентификация персонала:** Наблюдение помогает понять, как выглядит униформа сотрудников, подрядчиков (клининг, курьеры, техническое обслуживание), и как выглядят их пропуска.

Картографирование целей: На основе собранной информации составляется план. Определяются наиболее ценные цели — серверные, архивы, кабинеты топ-менеджеров — и прорабатываются маршруты к ним, выявляя потенциальные уязвимости.

Фаза 2: Методы физического проникновения — искусство обхода

На этом этапе применяются разнообразные техники, от высокотехнологичных до чисто психологических.

Клонирование RFID-пропусков: Цифровой двойник в вашем кармане Один из самых эффективных методов обхода СКУД — это клонирование электронных пропусков. Большинство компаний до сих пор используют устаревшие низкочастотные RFID-карты (125 кГц), которые чрезвычайно уязвимы для атак.

- **Технология клонирования:** Процесс занимает считанные минуты. С помощью компактного устройства, такого как Proxmark3 или даже Flipper Zero, злоумышленник может считать данные с карты-оригинала на расстоянии до 10-15 см — в толпе у входа, в лифте или в кафе. Затем эти данные записываются на пустую карту-болванку (например, T5577), создавая идеальную копию. В анонимном кейсе, с которого мы начали, пентестеры использовали Proxmark3 с Bluetooth-модулем, что позволило считать карту сотрудника и создать клон менее чем за 2 минуты, пока тот пил кофе.
- **Меры защиты:** Для защиты от клонирования рекомендуется использовать многофакторную аутентификацию (карта + PIN-код), переходить на современные высокочастотные карты с шифрованием (Mifare DESFire, LEGIC) и внедрять биометрическую верификацию.

Социальная инженерия: Атака на самое уязвимое звено — человека Социальная инженерия эксплуатирует не технические, а человеческие слабости: доверие, вежливость, страх и желание помочь. Это самый непредсказуемый, но часто самый успешный вектор атаки.

- **Техника "Забытый пропуск":** Пентестер, одетый в деловом стиле или в униформе подрядчика, подходит к входу одновременно с сотрудником и вежливо просит придержать дверь, ссылаясь на забытый дома пропуск. В утренней суете мало кто откажет.
- **Имперсонация курьера или технического специалиста:** Классический прием. Атакующий в форме курьерской службы с коробкой в руках или в спецодежде с ящиком инструментов выглядит убедительно. В одном из реальных кейсов пентестер от компании Pinkerton успешно проник в офис, представившись техником по обслуживанию систем вентиляции. Он предварительно позвонил на ресепшн, использовал профессиональный жаргон и назвал имена нескольких реальных сотрудников, после чего его пропустили без лишних вопросов.

- **Метод "Занятые руки":** Похож на "забытый пропуск", но еще эффективнее. Атакующий несет стопку коробок, стаканы с кофе или другие громоздкие предметы, физически не имея возможности достать пропуск. Почти любой человек инстинктивно придержит дверь.

Tailgating и Piggybacking: Пройти "паровозиком" Эти термины часто путают, но разница важна.

- **Tailgating (следование вплотную):** Неавторизованное лицо незаметно проскальзывает в дверь сразу за легитимным сотрудником, который может даже не заметить "хвост".
- **Piggybacking ("провоз на спине"):** Сотрудник сознательно пропускает постороннего, поддавшись на уловки социальной инженерии (например, придерживает дверь для "курьера").

Оптимальное время для таких атак — утренние часы пик и обеденные перерывы, когда поток людей максимален, а внимание охраны рассеяно.

Дампстер-дайвинг: Сокровища в мусорном баке Анализ мусора компании может дать невероятное количество ценной информации. И хотя это звучит как что-то из прошлого века, метод все еще работает. В мусорных контейнерах можно найти:

- Списки сотрудников, внутренние телефонные справочники.
- Корпоративные email-адреса для последующих фишинговых атак.
- Схемы сетей, IP-адреса, имена серверов.
- Финансовые отчеты, планы безопасности и другие конфиденциальные документы, которые не были должным образом уничтожены (например, через шредер).
- Выброшенные жесткие диски, USB-накопители и старые телефоны, с которых часто можно восстановить данные.

Фаза 3: Внутреннее перемещение и демонстрация доступа

Проникнув внутрь, пентестер должен доказать, что уязвимость реальна, и продемонстрировать максимальный уровень достигнутого доступа. Делается это с соблюдением строгих этических норм:

- **Размещение индикаторов:** Оставить на столе руководителя визитку, безобидный предмет или записку.
- **Фотофиксация:** Сфотографировать (не вынося и не копируя) открытые на столах конфиденциальные документы, схемы на досках в переговорных.
- **Доступ к критическим зонам:** Попытаться войти в серверную, архив или бухгалтерию и зафиксировать этот факт (например, оставив там USB-накопитель с текстовым файлом, без запуска вредоносного ПО).

Связь с требованиями по физической безопасности из ТНПА РБ

Хотя большинство коммерческих организаций в Республике Беларусь не подпадают под строгие требования, разработанные для ядерных и критически важных объектов, принципы, заложенные в Технических нормативных правовых актах (ТНПА), являются золотым стандартом и могут быть адаптированы для любого бизнеса.

Ключевые ТНПА по физической защите:

- **ТКП 531-2014 "Порядок анализа уязвимости ядерных объектов..."**: Этот документ вводит важнейшее понятие — **модель нарушителя**. Он классифицирует угрозы на:
 - **Внутренних нарушителей**: Сотрудники с легальным доступом.
 - **Внешних нарушителей**: Лица без права доступа.
 - **Комбинированные угрозы**: Сговор внешних и внутренних нарушителей. Эта модель заставляет компании думать не только о "хакере в капюшоне", но и о недовольном сотруднике или о человеке, обманутом социальной инженерией.
- **ТКП 360-2011, ТКП 426-2012, ТКП 389-2012**: Эти документы устанавливают фундаментальные принципы эшелонированной (многоуровневой) защиты:
 - **Категорирование зон**: Выделение защищенных, внутренних и особо важных зон (серверные, архивы).
 - **Физические барьеры**: Требования к стенам, дверям, замкам и турникетам.
 - **Контроль доступа**: Организация пропускного режима через КПП.
 - **Мониторинг и видеонаблюдение**: Постоянный контроль периметра и критических зон.

Уязвимости типового пропускного режима в белорусских компаниях:

Анализ реальных кейсов пентеста показывает, что даже при формальном наличии СКУД и охраны, слабые места типичны:

- **Уязвимые RFID-карты**: Использование дешевых карт без шифрования.
- **Неподготовленная охрана**: Сотрудники охраны обучены реагировать на силовые угрозы, но не на психологические манипуляции.
- **Отсутствие "антипассбэка"**: Система не блокирует повторный вход по одной и той же карте, что позволяет передавать ее другому лицу.
- **Слабый контроль подрядчиков**: Курьеры, клининг и технические специалисты часто получают доступ без должной проверки и сопровождения.
- **Неэффективная утилизация документов**: Отсутствие политики обязательного уничтожения бумаг через шредер.

Рекомендации по укреплению физической безопасности: строим свою крепость

На основе лучших мировых практик и принципов ТНПА РБ, можно сформировать комплексный план по защите вашего офиса.

Технические меры:

- **Модернизация СКУД:**
 - Переход на защищенные от клонирования карты (Mifare DESFire, LEGIC).
 - Внедрение многофакторной аутентификации (карта + PIN-код или биометрия) для особо важных зон.
 - Настройка функции "антипассбэк" (запрет повторного прохода без выхода).
- **Улучшение видеонаблюдения:**
 - Аудит и устранение "слепых зон".
 - Использование камер с видеоаналитикой для обнаружения нетипичного поведения.
 - Обеспечение надежного хранения архивов видеозаписей.
- **Укрепление физических барьеров:**
 - Установка турникетов полного роста или шлюзовых кабин для предотвращения tailgating.
 - Использование датчиков для контроля за одновременным проходом нескольких человек.
 - Установка сигнализации на двери, которые остаются открытыми слишком долго.

Организационные меры:

- **Обучение персонала:**
 - Регулярные тренинги по распознаванию методов социальной инженерии. Сотрудники — это первая линия обороны.
 - Внедрение строгой политики "не придерживать дверь незнакомцам" и "проверять всех посетителей".
 - Разработка четких процедур верификации подрядчиков и гостей.
- **Политика "чистого стола" и безопасной утилизации:**
 - Запрет оставлять конфиденциальные документы на столах без присмотра.
 - Обязательная блокировка компьютеров при уходе с рабочего места (даже на 5 минут).
 - Использование шредеров для всех бумажных документов перед их утилизацией.

- **Регулярные аудиты и пентесты:**

- Проведение периодических внутренних и внешних физических пентестов для выявления слабых мест.
- Анализ журналов доступа СКУД для выявления аномалий (например, входы в нерабочее время).

- **Управление доступом:**

- Применение принципа наименьших привилегий: сотрудники должны иметь доступ только в те зоны, которые необходимы им для работы.
- Немедленная деактивация пропусков уволенных сотрудников.

Этические и юридические аспекты

Важно понимать, что физический пентест — это не "легальный взлом". Это строго регламентированная процедура, которая требует:

- **Письменного разрешения** от руководства компании.
- **Четко определенной области тестирования (scope):** Что можно делать, а что нельзя.
- **Правил проведения (rules of engagement):** Например, запрет на причинение физического ущерба.
- **Протокола эскалации:** Что делать при обнаружении критической уязвимости.
- **Полной конфиденциальности** результатов.

Физическая безопасность — это фундамент, на котором строится вся система корпоративной защиты. Самые совершенные цифровые бастионы рухнут, если злоумышленник сможет просто войти в серверную и подключить свое устройство. Клонирование пропусков, психологические манипуляции, простое человеческое любопытство и вежливость остаются мощнейшими векторами атак в 2025 году.

Требования ТНПА Республики Беларусь, изначально разработанные для объектов критической инфраструктуры, предоставляют бесценную методологию для любой коммерческой организации. Адаптация этих принципов — моделирование угроз, эшелонированная защита, строгий контроль доступа и регулярное обучение персонала — позволяет построить по-настоящему надежную систему безопасности.

Успешная защита — это не просто покупка дорогой СКУД. Это интеграция технических средств, четких организационных политик и, самое главное, формирование культуры безопасности у каждого сотрудника. Только комплексный подход, регулярно проверяемый реалистичными тестами на проникновение, может обеспечить надежную защиту от всего спектра современных угроз.

Как вам статья?
